

Phishing Analysis

Email has become one of the most critical communication channels in today's digital world, enabling individuals and organizations to exchange information quickly and easily. However, this convenience has also made email a prime target for cybercriminals seeking to steal sensitive data or gain unauthorized access to corporate networks.

Email threats are among the most common types of attacks encountered by **Security Operations Center (SOC)** analysts, and they often occur multiple times during a working shift. Moreover, malicious emails are often the first step in an attacker's attempt to gain access to a target environment. Given the increase in these types of threats, SOC analysts and cyber investigators must understand attackers' techniques to initiate attacks via email and how to investigate and respond to email threats.

In the cyberattack chain, once an attacker has conducted reconnaissance against the target victim's environment and infrastructure, and prepared the necessary weapons and equipment, the next step is to determine their preferred method and technique to gain initial access to the victim's environment. Attackers have several techniques at their disposal to gain initial access, including sending phishing emails, exploiting public-facing applications, and stealing valid remote credentials such as a VPN or RDP. Understanding the various techniques attackers use to gain initial access is crucial for security professionals to identify and prevent attacks before they can cause damage.

As per the IBM Security X-Force report, 41% of the attackers prefer phishing techniques to gain initial access to the victim's environment, either by sending a weaponized document or a malicious link to the target victims

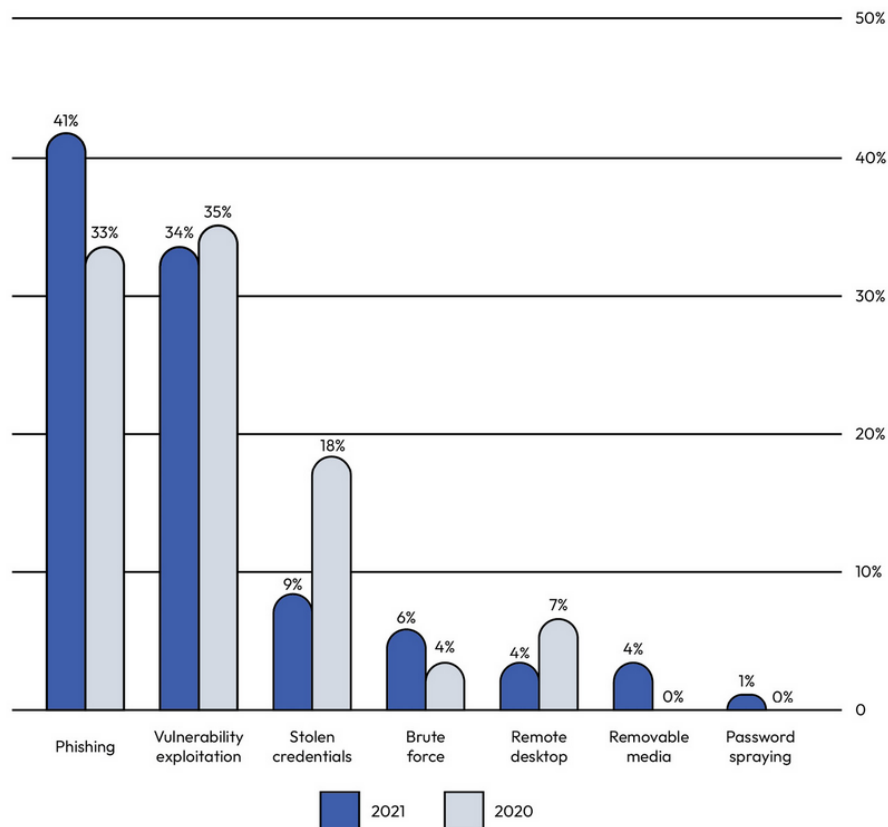


Figure 1 The top infection vectors from the IBM Security X-Force Threat Intelligence Index 2022

Why do attackers prefer phishing emails to gain initial access?

A **phishing email** is a type of social engineering attack where an attacker tricks target victims into opening a malicious file or link or providing personal or confidential information, such as passwords and credit card numbers, through fraudulent emails. The reason why phishing is a preferred and successful way for attackers to gain initial access to the victim's environment is due to several factors, including the following:

- It is easy during the reconnaissance phase to acquire a list of target victim users' email addresses.

The reconnaissance phase is the first step taken by intruders to breach a target environment. This phase can last for hours, days, weeks, or even months. During this phase, attackers collect information about the target victim, including their email addresses, which can be used to deliver a weaponized document or link. Attackers can collect email addresses in several ways, such as through job postings, social media platforms such as LinkedIn, third-party subscriptions, data leaks on the dark web, Wayback Machine archives such as [Archive.org](https://archive.org), or data collection from marketing platforms such as [ZoomInfo.com](https://zoominfo.com).

- It is not hard to prepare a weaponized attachment or link.

It is relatively easy for an attacker to upload malware to legitimate cloud platforms and then share the download link with the victim through email. They can also weaponize a document through **Visual Basic for Applications (VBA)** macros or send the malware executable itself in a compressed format, all of which can be sent to the victim via email.

- Many users lack security awareness.



Macro File VBA Demo.

Email threat types

Email threats are every threat your environment faces when deciding to use an email service. They are not limited to phishing emails only; some attackers also use email for blackmailing, information leakage, data exfiltration, and lateral movement. In this section, we will focus on email threats that originate from external sources and discuss in detail four common types of email threats that organizations face:

- Spearphishing attachments
- Spearphishing links
- Business Email Compromise
- A **spearphishing attachment** involves adversaries sending phishing emails to target victims with malicious attachments, either to gain initial access to their systems or harvest their credentials. After defining a list of the victims' email addresses and preparing the weaponized attachment, the attacker become ready to send the email to the victim with one click. However, the question remains, which weaponized attachment will an attacker choose? Let us discuss the most common weaponized attachment types used by threat actors.

- **Phishing and spearphishing** are both types of email attacks that aim to steal sensitive information or compromise a target's computer system. While both methods have the same ultimate goal, the primary difference between the two is the level of targeting involved. Phishing emails are mass email attacks that are sent to a randomly large number of people. In contrast, spearphishing emails are much more targeted and personalized. They are specifically crafted to target a particular individual or group of individuals, such as employees of a particular company or members of a specific organization.
- **Phishing attachment types** When you hear the term *phishing attachment*, you may think about just one or two types of attachments, but due to the different preferred attacker methods, target victims' infrastructure and business, and attacker goals, there are variants of the malicious attachment types that attackers email to their target victims. The following are the five most common examples of phishing attachment types:

- **Malicious Microsoft Office documents:** Attackers often use a weaponized Microsoft document with VBA macros, such as Excel, Word, or PowerPoint documents, and send it to the target victim to trick them into opening it, thereby gaining initial access to their machine. This type of attachment is the most commonly used in spearphishing attacks because almost all enterprises use Microsoft documents in their day-to-day work. Additionally, it is easy for attackers to develop a weaponized Microsoft document. Weaponized Microsoft documents provide unlimited features to attackers, and also, they can exploit known vulnerabilities that affect Office apps.
- **Malicious PDF files:** Attackers can also use a decoy PDF file that contains malicious code to exploit PDF reader vulnerabilities and gain initial access to the victim's system, or harvest their credentials. PDF files are a popular choice for attackers because it allows them to easily embed malicious JavaScript code, and the inclusion of links, images, and fonts can make a file appear legitimate and increase the likelihood that the victim will interact with it. This type of attack is often used in spearphishing campaigns, where the attacker targets a specific individual within an organization with a highly personalized email that contains a malicious PDF attachment.
- **Compressed files (.rar, .7z, zip, etc.):** An attacker may send a compressed file containing executable malware to the victim, tricking them into extracting it and executing the executable file.
- **ISO images:** Recently, we observed a notable increase in the use of .iso files to deliver malware to target recipients. Attackers depend on ISO image files because they are like disc images; hence, they can be used to bypass file filters and evade antivirus detection.
- **HTML files:** An attacker may send an HTML phishing attachment that impersonates familiar login pages, such as the Microsoft login page, the DHL login page, or a bank login page, to harvest the victim's credentials

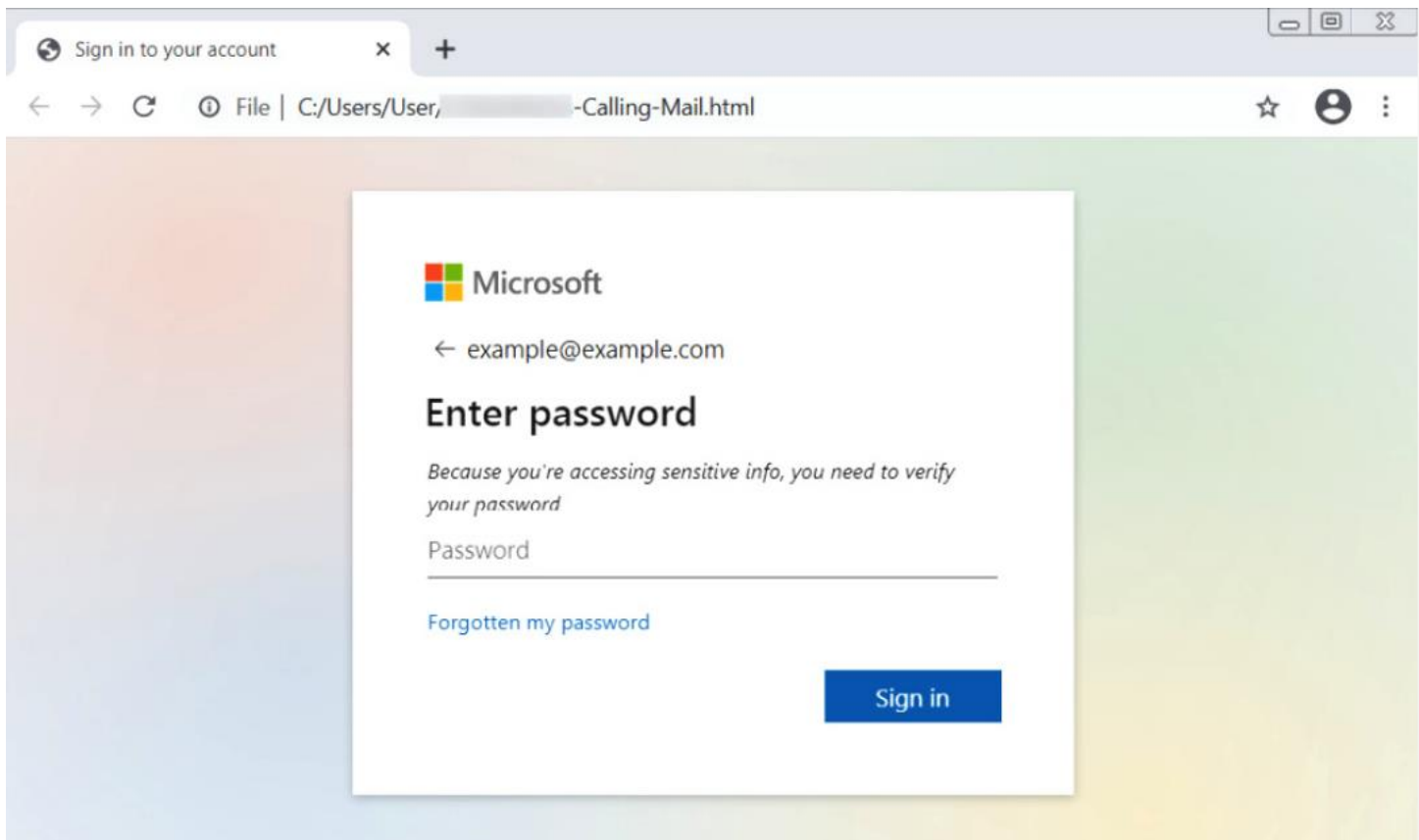


Figure 2 An HTML phishing attachment impersonating a Microsoft login page

As you can see, an attacker developed an HTML phishing file impersonating the Microsoft login page to trick the victim into entering their credentials.

Spearphishing Link

A **spearphishing link** involves adversaries sending spearphishing emails to target victims with a malicious link, to either harvest their credentials or trick them into downloading malware and executing it on their machine, thus gaining initial access to their systems. As with all email threats, after defining a list of the victim's email addresses and preparing the phishing link, the attacker is ready to send an email to the victim. But what is the attacker's purpose in sending the spearphishing link to the victims? Let us discuss the two most common types of phishing links used by attackers.

Phishing link types

As we mentioned before, every adversary has different intentions. Some of them just want to harvest a victim's credentials, while others want to gain an initial foothold in the victim's system. As with spearphishing attachments, there are variants of malicious link types that attackers use to mail to target victims. The following are two common examples of phishing link types:

- **A phishing link to harvest credentials:** One of the forms of a credential harvesting attack is when the attackers send a phishing email armed with links to bogus websites to trick a user into entering their credentials. To host their phishing page, an attacker may use their own domains or abuse legitimate web applications hosting domains, such as **appspot.com** and **web.app** domains. In 2014, an American multinational financial services company fell victim to a cyberattack. The attack started when attackers sent phishing emails to employees that contained a link to a fake website resembling the company's VPN login page. The employees were tricked into entering their login credentials, which were then harvested by the attackers. With access to the company's network, the attackers were able to steal data on more than 76 million households and 7 million small businesses.
- **A phishing link to download malware:** An attacker may host the malware on their web server or well-known legitimate cloud file hosting services, such as MEGA, OneDrive, or Dropbox, and then share the file sharing link with their victim over email and try to trick them into downloading and executing the malicious executable. In 2017, a global law firm fell victim to a massive cyberattack that used a phishing email to deliver malware. The attack started when an employee received an email that appeared to be from a client, with a subject line referencing a real estate matter. The email contained a link that the employee clicked on, which then downloaded malware onto the firm's network. The malware quickly spread throughout the firm's global network, infecting systems and encrypting files. The attackers demanded a ransom payment in exchange for the decryption key. The attack caused significant disruption to the firm's operations, and it took several weeks to fully recover.

Business Email Compromise (BEC)

Business Email Compromise (BEC) is a type of email scam where the attacker targets a specific individual within a company who has access to financial information, such as an executive or a finance employee, and tricks them into making a fraudulent financial transaction or wire transfer. BEC attacks often involve the email thread hijacking technique, which we will discuss in the *Social engineering techniques to trick the victim* section, or spoofing the email address of a trusted partner or company executive to convince the victim to transfer money or sensitive information to the attacker's account.

BEC attacks are one of the most trending and result in significant financial losses for organizations, making them a growing concern in the cybersecurity community.

In 2018, the US Department of Justice reported that a Nigerian cybercriminal group called Gold Galleon had used the email thread hijacking technique in BEC attacks against maritime shipping companies. The group would first gain access to an employee's email account through spearphishing or other means. Once they had access, they would search the employee's emails for ongoing conversations related to cargo shipments and then use the email thread hijacking technique to intercept and take over the thread. Using this technique, the attackers could impersonate the legitimate email sender and request that payment for the cargo shipment be redirected to a new bank account. Since the email appeared to be part of an ongoing conversation, the victim would often not suspect anything was wrong and would comply with the request, resulting in significant financial losses for the targeted companies.

In one case, the Gold Galleon group was able to steal over \$1 million from a shipping company using this technique. The group is believed to have targeted over 100 maritime shipping companies in the United States, Europe, and Asia, with losses totaling tens of millions of dollars.

Attacker techniques to evade email security detection

As cyber defense and security controls have become increasingly advanced, attackers have become more creative in their techniques to evade detection by email security solutions. Many critical organizations have now deployed such solutions to check every email sent from external senders to internal recipients, and they have skilled SOCs and threat-hunting teams to detect and respond to threats. In this section, we will explore some of the techniques that attackers use to bypass email security solutions and carry out successful attacks:

- **Using newly created domains to send a malicious email:** Modern email security solutions are fortified with threat intelligence feeds, which include an updated list of sender domains with a bad reputation resulting from their malicious use in previous phishing campaigns. To evade detection by email security solutions that block malicious emails due to sender domain reputation, attackers often create new domains that have not been used previously in any malicious activities.
- **Using non-blacklisted SMTP servers:** Like malicious sender domain feeds, a secure email gateway can be enriched with threat intelligence feeds of the known malicious **Simple Mail Transfer Protocol (SMTP)** server IPs that are usually used during phishing campaigns, which are blocked. To avoid their malicious emails being blocked by email security solutions due to the bad reputation of the SMTP server IPs, attackers tend to use non-blacklisted IP addresses.
- **Sandbox analysis evasion:** Email gateway security appliances have significantly improved over time and now include sandbox technology that can analyze every attachment sent from external email senders to internal employees. We will deep dive into sandboxing later in the book, but for now, it is worth knowing that **sandbox** technology is a vital tool, used by cybersecurity analysts and solutions to analyze the behavior of files and executables before running them in a real environment, ensuring that they are not harmful. However, attackers are well aware of this technology and use various techniques to evade sandbox detection efforts, such as the following:
 - **Malware sleep:** To evade detection from sandbox analysis, an attacker can take precautions by, for example, incorporating a sleep time of up to three minutes in their malware code after execution, thereby delaying the start of any malicious activity until after the sandbox analysis has been completed and avoiding detection by the sandbox's real-time monitoring.
 - **Encrypted file:** An attacker can employ a technique of sending a malware file to the victim in the form of a compressed folder or document file, encrypted with a password, which is then shared with the victim via the email body for decryption. Since submitting an attachment file to a sandbox by an email gateway is not an interactive submission process, the password cannot be provided to the sandbox during file analysis to decrypt and analyze the file. Therefore, the sandbox fails to analyze the attachment, allowing it to pass through to the victim's mailbox undetected.
 - **Sandbox discovery:** After the malware is executed, it may check for the presence of a virtual machine environment, search for any malware analysis tools, and detect abnormal user activity to determine whether it is running in a sandbox environment. If the malware detects any signs of sandbox technology, it may alter its intended actions, stop running, go into sleep mode, or take other evasive actions to avoid detection by the sandbox.

Let's Create Fake Login Portal using **Setoolkit**

To publish a fake login portal created using **SEToolkit (Social-Engineer Toolkit)** on the internet using a public domain, you need to configure your environment to allow external access. This explanation is

For Educational Purposes Only !!

To use **Ngrok** to publish a website with an HTTPS-enabled Ngrok domain, follow these steps:

1. Install Ngrok

If you haven't already installed Ngrok, download and install it:

1. Download Ngrok:
 2. `wget https://bin.equinox.io/c/bNyj1mQVY4c/ngrok-stable-linux-amd64.zip`
 3. `unzip ngrok-stable-linux-amd64.zip`
 4. `sudo mv ngrok /usr/local/bin`
 5. Confirm installation:
 6. `ngrok --version`
-

2. Sign Up and Authenticate

1. Visit [Ngrok's website](#) and sign up for a free or paid account.
2. After signing in, find your **authtoken** in the dashboard.
3. Authenticate Ngrok with your account by running:
4. `ngrok config add-authtoken YOUR_AUTHTOKEN`

Replace YOUR_AUTHTOKEN with the token you copied from the Ngrok dashboard.

3. Start Your Local Website

Make sure the website is accessible on `http://localhost`.

4. Expose the Website with Ngrok

Run Ngrok to expose your local website to the internet:

1. Start Ngrok on port 80:
2. `ngrok http 80`
3. Ngrok will generate two URLs: one for HTTP and one for HTTPS. Example:

4. Forwarding `http://1234-5678.ngrok.io -> http://localhost:80`
 5. Forwarding `https://1234-5678.ngrok.io -> http://localhost:80`
 6. Use the HTTPS URL (`https://1234-5678.ngrok.io`) to share your website securely over the internet.
-

5. Optional: Use a Custom Subdomain (Paid Plan)

If you have a paid Ngrok plan, you can use a custom subdomain:

1. Run Ngrok with the `-subdomain` flag:
2. `ngrok http -subdomain=yourcustomname 80`

Example:

`https://yourcustomname.ngrok.io`

6. Test and Access

Visit the HTTPS Ngrok URL in a browser or share it with others to access your website over the internet.

VBA Macro

```
Sub AutoOpen()  
    ' This macro will launch Firefox and navigate to Google  
    Dim objShell As Object  
    Set objShell = CreateObject("WScript.Shell")  
  
    ' Open Firefox and navigate to Google  
    objShell.Run "firefox https://www.google.com"  
End Sub
```